Day 53

"CLOUD SECURITY"

AWS CAF – Security Perspective

Helps organizations implement suitable security controls when adopting the cloud.

Key Capabilities:

- Identity & Access Management (IAM): Manage identities, permissions, and lifecycle integration.
- Detective Controls: Provide visibility and transparency into AWS operations.
- Infrastructure Security: Apply security controls to cloud resources.
- Data Protection: Safeguard data at rest and in transit.
- Incident Response: Identify, respond, and manage incidents to minimize damage.

Approach:

- Preventative controls – stop incidents before they occur.
- Detective controls – monitor and detect suspicious activity.
- Responsive actions – automate recovery and remediation.
- Governance – enforce policies, compliance, and accountability.

AWS Incident Response Plan (IRP)

An IRP helps customers detect, handle, and minimize damage while finding and fixing the cause of incidents.

Goals:

- Identify indicators of incidents
- Classify incident types
- Find root causes
- Follow incident workflows
- Prepare for incidents
- Educate staff

Implementation Steps in AWS:

1. Educate → Train staff on AWS cloud technologies.
2. Prepare → Equip IR team to detect/respond quickly.
3. Simulate → Run scenarios of expected/unexpected events.
4. Iterate → Learn from simulations to reduce risks and response time.

Design Goals for Cloud Incident Response (CIR):

- Build Response Objectives → Work with stakeholders/legal teams to set clear goals (mitigation, recovery, forensics).
- Respond to Events → Apply response patterns where the data and incident occur.
- Preserve Evidence → Save logs, snapshots, and artifacts in a secure, centralized account.
- Adopt Redeployment Techniques → Fix misconfigurations via redeployment with correct settings.
- Implement Automation → Automate responses for recurring incidents to save time.
- Choose Scalable Solutions → Ensure IR scales with the organization's cloud usage.
- Improve the Process → Continuously refine processes, tools, and training through simulations.

Indicators of Cloud Security Events

- Logs & Monitors → Use VPC Flow, S3 logs, CloudTrail, GuardDuty, Security Hub, Detective, Macie, CloudWatch, Route 53 health checks, and app-specific logs.
- Billing Activity → Unexpected spikes or drops in billing.
- Threat Intelligence → Correlate 3rd-party threat intel with AWS monitoring.
- Partner Tools → Leverage AWS Partner Network (APN) security solutions.
- One-time Contact → Reports from users, staff, or developers via ticketing/email/web forms.
- AWS Support → Notifications from AWS about malicious activity.

AWS Incident Detection & Response Capabilities

- Investigate Security Events → Use AWS logs (CloudWatch, CloudTrail, S3 access logs).
- Centralized Logging → Consolidate logs in S3; query with Athena.
- Partner Products → Use APN security tools for log analysis.
- AWS Services → Gain insights via GuardDuty, Security Hub, etc.

AWS Incident Response Plan – Educate

- **Shared Responsibility**
  - AWS → Secures infrastructure (host OS, hardware, facilities).
  - Customer → Secures OS, IAM, network configs, security groups, NACLs, etc.
  - Responsibilities differ based on chosen AWS services.
- **Incident Response in Cloud (Design Goals)**
  1. Build Response Objectives → Define goals with stakeholders (mitigation, recovery, forensics).
  2. Respond to Events → Apply response patterns where the event/data occur.
  3. Preserve Evidence → Store logs, snapshots, and evidence (central security account + retention policies).
  4. Adopt Redeployment → Redeploy with correct configs when misconfigurations cause issues.
  5. Implement Automation → Automate frequent responses to save time/effort.
  6. Choose Scalable Solutions → Ensure IR matches cloud scalability and reduces detection-to-response time.

AWS Incident Response Plan: Prepare

Prepare Technology

- Enable access to AWS accounts, tools, and services for detection and response.
- Create runbooks (manual and automated) for quick responses.
- Establish baseline operations to detect deviations.

Prepare People

- Define roles and responsibilities.
- Define response mechanisms.
- Build a receptive and adaptive security culture.

Cloud Provider Support

- AWS Managed Services → Infrastructure management using best practices.
- AWS Support → Tools and programs to optimize performance and reduce costs.
- DDoS Response → AWS Shield for managed protection.
- Support Escalation Path:
  1. Submit support case
  2. Technical Account Manager (TAM)
  3. On-call Operations Manager
  4. Global Enterprise Support Manager
  5. Director of Support Engineering
  6. VP of AWS Support

AWS Security Incident Response Plan: Simulation

Security Incident Response Simulation (SIRS):

- A method to practice the IRP in real-time scenarios.
- Helps the incident response team prepare, test, and improve their response capabilities.

Simulation Steps:

1. Identify an issue of importance
2. Find skilled security engineers
3. Develop a realistic model
4. Build and test the scenario elements
5. Invite other security individuals and cross-organizational participants
6. Run the simulation
7. Celebrate, measure, improve, and repeat simulations

AWS Incident Response Plan: Iterate

Key Idea:

- Use the outputs from SIRS (Security Incident Response Simulation) as inputs for improving response procedures.
- Focus on building and refining runbooks.

Creation of Runbooks:

1. Define manual procedures for responding to security events.
2. Test and iterate on runbook patterns.
3. Identify exceptions and design alternate solutions.
4. Convert solutions into code-based responses for automation.
5. Automate gradually so responses can be triggered by alerts or events.
6. Runbooks improve the speed and efficiency of the incident response cycle.

AWS Incident Response Plan: Automate

Purpose:

- Enhance AWS cloud security by automating repetitive and routine incident response tasks.

Incident Response Automation:

1. Automates handling of **normal and repetitive alerts**, letting the team focus on serious incidents.
2. Converts the **remediation steps** of a security event into **code logic**.
3. Run the code to handle incidents efficiently.
4. Gradually automate **more common incidents** for faster response.

Event-driven Response:

1. Triggers automatic remediation when a security event occurs.
2. Reduces the time gap between detection and response.
3. Notifies responders about successful resolution.
4. Provides feedback loops to understand the cause and prevent future incidents.
5. Continuously improves the security posture of the cloud environment.

--The End--